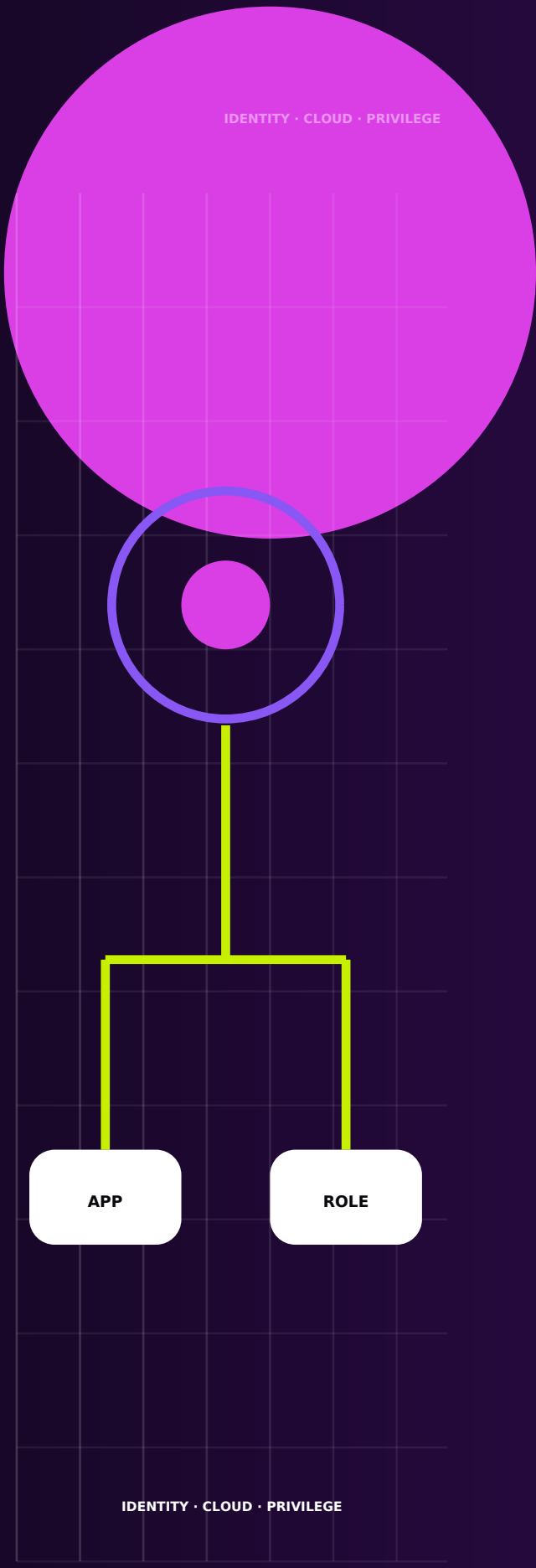
DETECTION THREAT LANDSCAPE

SERVICE PRINCIPAL SELF-ROLE ASSIGNMENT TELEMETRY VALIDATION

Raw Entra role-assignment collection with candidate application and target identifier extraction



VALIDATION QUERY

CONFIDENCE: MEDIUM

REPORT TYPE
cloud-identity

STATUS
Untested implementation sketch

PRIMARY PLATFORM
Microsoft Sentinel

OPERATIONAL VALUE
9 / 10

01

Executive Assessment

Decision-grade summary with explicit evidence boundaries.

ASSESSMENT

DECISION

Publish a non-alerting schema-validation query. The observed behavior is high impact, but production self-assignment logic must wait until representative tenant events establish how the initiating service principal, assigned principal and directory role are encoded in InitiatedBy, TargetResources and modifiedProperties.

SOURCE-CONFIRMED

- Huntress directly observed credential additions, failed certificate upload, role grants and...
- Microsoft Entra documents role-management activities and the AuditLogs fields used by the...
- MITRE ATT&CK T1098.003 covers adding cloud roles for persistence or privilege escalation. [C006]

ANALYST ASSESSMENT

- Comparing an initiating service-principal object ID with a target principal ID is a high-value...
- The actor's pace and tooling changes are useful incident context but are less durable than the...

DETECTION ASSUMPTIONS

- The tenant exports Microsoft Entra audit events to the Sentinel AuditLogs table with unmodified...
- At least one target resource row contains the assigned principal or role context needed to distinguish...

KEY FINDINGS

FINDING 1

Huntress observed a ConnectWise-related application identity assigning itself Global Administrator and granting roles to sibling principals during unauthorized tenant activity. [C001]

FINDING 2

Application-only audit events lacked source IP and affected tenants did not retain the Microsoft Graph request logs needed to reconstruct every read and request. [C002]

FINDING 3

AuditLogs documents InitiatedBy and TargetResources as dynamic fields, so raw preservation and tenant-specific mapping are prerequisites for defensible equality logic. [C003][C004][C005]

EVIDENCE BOUNDARY

The exact nested representation of direct, PIM, eligible and service-principal role assignments has not been validated in the target tenant. The public evidence does not prove that AI performed each role-assignment request or that every matching tenant event is connected to Storm-0940.

02

Threat Mechanics

Technical mechanism, observable transitions and supported scope.

ATTACK FLOW

TECHNICAL BACKGROUND

A compromised application credential can authenticate as a service principal and call Microsoft Graph or directory role-management operations without an interactive user. Entra audit records preserve the initiating app or user and changed target resources as dynamic structures. The durable detection opportunity is an application identity granting an administrative role to itself or a related principal, but the exact identifier and role placement can differ across direct and PIM workflows. [C001][C003][C004][C005]

1

VENDOR CREDENTIAL ABUSE

Compromised ConnectWise application credentials reach downstream Microsoft 365 tenants. Observable: Application sign-ins, application identity and unusual user agent or tenant access.

2

CREDENTIAL PLANTING

Secrets are added, removed or retried and a certificate upload is attempted. Observable: Application-management audit events and changed credential properties.

3

ROLE ESCALATION

An application identity grants itself Global Administrator and roles are granted to related principals. Observable: Successful role-assignment events with initiating-app and target-resource identifiers.

4

RAPID ADAPTATION

Tooling changes between runs after failures. Observable: High-resolution chronology and preserved raw user agents; not a stable detection condition.

5

VISIBILITY BOUNDARY

Graph reads and some application-only source context are unavailable. Observable: Missing Graph activity and absent source IP in application-only audit events.

03

Telemetry & Evidence Model

Minimum data contract and known visibility gaps.

DATA CONTRACT

PRIMARY PLATFORM

Microsoft Sentinel. Collect successful supported role-assignment events, preserve raw dynamics, expand target resources and expose candidate initiating-app and target identifiers without promoting them to an alert.

FIELD / TABLE	STATUS	PURPOSE
AuditLogs	**Required**	Microsoft Entra directory and role-management activity.
OperationName	**Required**	Select supported role-assignment activities.
Result	**Required**	Limit validation to successful recorded operations.
InitiatedBy	**Required**	Raw initiating app or user and candidate service-principal identifiers.
TargetResources	**Required**	Raw changed principals, roles and modified properties.
Id / CorrelationId	**Required**	Event identity and workflow correlation.
Graph activity logs	**Enrichment**	Request-level context when licensing and collection permit.
Service principal inventory	**Enrichment**	Owner, app ID, object ID, expected roles and vendor relationship.

KNOWN VISIBILITY GAPS

No source IP for application-only audit events Graph activity logging disabled Dynamic schema variation Retention gaps Deleted service principals

04

Primary Detection Logic

Native query, explicit condition evidence and match meaning.

KQL

```
// Rule: [T1098.003] Service Principal Role-Assignment Schema Validation
// MITRE ATT&CK: T1098.003 (Additional Cloud Roles)
// Classification: Validation query - Untested implementation sketch
// Status: Untested implementation sketch
// Confidence: Medium
// Platform: Microsoft Sentinel / Log Analytics
// Prerequisite: Microsoft Entra ID audit logs connected to the AuditLogs table.
// Logic: collect successful role-assignment events, preserve raw dynamic fields,
// and expose candidate initiating-app and target-resource identifiers.
// A match proves: Entra recorded a successful supported role-assignment activity.
// A match does not prove app-to-self assignment, Global Administrator, compromise,
// Storm-0940/ConnectWise involvement, malicious intent, or AI-agent use.
// Expected false positives: normal administration, PIM and application governance.
// Coverage limits: tenant-specific nested representation, missing Graph activity
// logs, no source IP on application-only events and retention/licensing gaps.
// Evidence claims: C001, C002, C003, C004, C005, C006
AuditLogs
| where OperationName in ("Add member to role", "Add eligible member to role")
| where Result =~ "success"
| extend
    InitiatorAppId = tostring(InitiatedBy.app.appId),
    InitiatorServicePrincipalId = tostring(InitiatedBy.app.servicePrincipalId),
    InitiatorAppName = tostring(InitiatedBy.app.displayName),
    InitiatorUserId = tostring(InitiatedBy.user.id),
    InitiatorUserPrincipalName = tostring(InitiatedBy.user.userPrincipalName)
| mv-expand Target = TargetResources to typeof(dynamic)
| extend
    TargetId = tostring(Target.id),
    TargetType = tostring(Target.type),
    TargetDisplayName = tostring(Target.displayName),
    TargetModifiedProperties = Target.modifiedProperties,
    CandidateSelfAssignment = iff(
        isnotempty(InitiatorServicePrincipalId)
        and InitiatorServicePrincipalId =~ TargetId,
        true,
        false
    )
| project TimeGenerated, Id, CorrelationId, OperationName, Category,
          LoggedByService, Identity, InitiatorAppName, InitiatorAppId,
          InitiatorServicePrincipalId, InitiatorUserId,
          InitiatorUserPrincipalName, TargetId, TargetType,
          TargetDisplayName, TargetModifiedProperties,
          CandidateSelfAssignment, InitiatedBy, TargetResources,
          Result, ResultDescription
| order by TimeGenerated desc
```

WHAT A MATCH PROVES

Microsoft Entra recorded a successful supported role-assignment operation and the query extracted the displayed raw and candidate fields.

WHAT IT DOES NOT PROVE

Service-principal self-assignment, Global Administrator, compromise, malicious intent, Storm-0940/ConnectWise involvement or AI-agent use.

MATURITY

Validation query - Untested implementation sketch. Collect successful supported role-assignment events, preserve raw dynamics, expand target resources and expose candidate initiating-app and target identifiers without promoting them to an alert.

05

Triage & Hunting Playbook

Evidence-preserving workflow from match to disposition.

WORKFLOW

01

Export the complete raw AuditLogs event before flattening and preserve Id, CorrelationId, InitiatedBy, TargetResources and modifiedProperties.

02

Resolve initiating appId and servicePrincipalId against current and historical service-principal inventory, ownership and vendor records.

03

Identify the assigned principal and role template/display name; distinguish direct, PIM, eligible and administrative workflows.

04

Compare initiating and target object identifiers only after confirming their semantics in representative local events.

05

Review adjacent credential additions, application deletions, application sign-ins, Graph activity, consent and role removals.

06

Escalate only when unauthorized ownership, self/related-principal assignment or corroborating compromise evidence is established.

DISPOSITION RULE

Escalate only when the evidence establishes the behavior described by the query. Service-principal self-assignment, Global Administrator, compromise, malicious intent, Storm-0940/ConnectWise involvement or AI-agent use.

06

False Positives & Validation

Overlap model, controlled checks and promotion gate.

QUALITY GATE

LEGITIMATE APPLICATION GOVERNANCE

Validate owner, change ticket, expected role and approved automation identity.

PIM ACTIVATION OR ELIGIBLE ASSIGNMENT

Separate PIM workflows by operation, LoggedByService, target type and modified properties.

ADMINISTRATIVE ROLE DELEGATION

Resolve the human or automation owner and confirm the target principal differs from the initiating application.

VALIDATION SEQUENCE

- Export representative user-initiated, service-principal, direct, eligible and PIM role-assignment events.
- Map InitiatedBy appId/servicePrincipalId and every TargetResources element without discarding raw JSON.
- Perform an authorized low-risk application role-assignment control in a test tenant and capture the complete event.
- Confirm how Global Administrator and Privileged Role Administrator are represented by display name and template ID.
- Measure whether candidate self-assignment equality is stable and whether any legitimate workflow produces the same condition.

SUCCESS

A controlled app-to-self or app-to-related-principal assignment yields stable comparable identifiers and role context while benign workflows are correctly characterized.

REJECTION

Reject production promotion when initiator, target or role semantics are ambiguous, absent, licensing-hidden or inconsistent across assignment paths.

PROMOTION GATE

Retain raw positive and negative samples, prove identifier semantics and role extraction, then implement and test the exact self/related-principal condition.

07

Analyst Assessment & References

Coverage statement, open questions and source record.

FINAL

CONCLUSION

The self-assignment behavior is an excellent high-impact detection target, but the current defensible artifact is a schema-validation query. The report deliberately refuses to infer principal equality or malicious intent from unvalidated dynamic mappings. Once local samples establish stable identifiers and role semantics, this package can become a production candidate.

MITRE ATT&CK

T1098.003

PRIMARY AND AUTHORITATIVE REFERENCES

S001 Huntress - AI, Scripts, Operator: Inside the ConnectWise Attack (2026-10-26)

hxxps://www[.]huntress[.]com/blog/connectwise-attack-ai

S002 Huntress - ConnectWise (SkyKick) Vendor Credentials Abused in M365 Attacks (2026-10-16)

hxxps://www[.]huntress[.]com/blog/vendor-credential-enables-unauthorized-access

S003 Microsoft Learn - AuditLogs table (2026-08-28)

hxxps://learn[.]microsoft[.]com/en-us/azure/azure-monitor/reference/tables/auditlogs

S004 Microsoft Learn - Microsoft Entra audit log categories and activities (undated)

hxxps://learn[.]microsoft[.]com/en-us/entra/identity/monitoring-health/reference-audit-activities

S005 Microsoft Learn - directoryAudit resource type (undated)

hxxps://learn[.]microsoft[.]com/en-us/graph/api/resources/directoryaudit?view=graph-rest-1[.]0

S006 MITRE ATT&CK - Account Manipulation: Additional Cloud Roles (T1098.003) (2025-10-24)

hxxps://attack[.]mitre[.]org/techniques/T1098/003/

OPEN QUESTIONS

The exact nested representation of direct, PIM, eligible and service-principal role assignments has not been validated in the target tenant. The public evidence does not prove that AI performed each role-assignment request or that every matching tenant event is connected to Storm-0940.

DOCUMENT CONTROL

Schema 2.0 | Layout 2.0 | Maturity validation | Confidence Medium | No customer data | Evidence ledger required